UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

| | | |
|---|---|---|
| COURSE | : | COMPUTER SECURITY |
| COURSE CODE | : | CSC662 |
| EXAMINATION | : | OCTOBER 2026 (MOCK) |
| TIME | : | 3 HOURS |

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

*This marking scheme consists of 15 printed pages*

© Hak Cipta Universiti Teknologi MARA 

# CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

*Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.*

*Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.*

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

*Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.*

## PART A - QUESTION 1

### A1a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain two formal security models used for access control, stating the specific security concern each model is designed to address.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The Chinese Wall model is a confidentiality access control policy that addresses conflicts of interest for consultants or contractors. | "Strictly speaking, this is not an integrity policy, but an access control confidentiality policy." | 024 - Formal Security Model, slide 21 | 024 - Formal Security Model::s21::1 | 0.33 LOW | partly supporte |
| 2 | The Chinese Wall policy is crafted to solve the specialized problem of conflicts of interest, showing that policies can target very specific concerns. | "Unlike previous policies, Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor." | 024 - Formal Security Model, slide 27 | 024 - Formal Security Model::s27::1 | 0.50 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 27*

### A1b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State six points about the access control matrix, access control lists and capability lists as access control structures, covering what each structure represents and one advantage or disadvantage of each.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The access control matrix is described as a basic control structure for implementing access policies. | "ACM is a basic control structure." | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.43 LOW | supported |
| 2 | A strength of the access control matrix is that it is clearly defined and easy to verify. | "Advantages: clarity of definition easy to verify" | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.25 LOW | supported |
| 3 | A weakness of the access control matrix is that it scales poorly and handles changes | "Disadvantages: poor scalability poor handling of changes" | 023 - Access Control and Authorization, slide 8 | 023 - Access Control and Authorization::s08::1 | 0.38 LOW | supported |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | poorly. | | | | | |
| 4 | An access control list is an object-centred description of access rights. | "ACL is an object-centered description of access rights:" | 023 - Access Control and Authorization, slide 10 | 023 - Access Control and Authorization::s10::1 | 0.67 | supported (ste gate) |
| 5 | A capability list is a subject-centred description of access rights. | "C-List is a subject-centered description of access rights:" | 023 - Access Control and Authorization, slide 9 | 023 - Access Control and Authorization::s09::1 | 0.67 | supported (ste gate) |
| 6 | A disadvantage of capability lists is that they require extra integrity protection. | "need for extra integrity protection" | 023 - Access Control and Authorization, slide 9 | 023 - Access Control and Authorization::s09::1 | 0.43 LOW | supported |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8; 023 - Access Control and Authorization, slide 9*

## PART A - QUESTION 2

### A2a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain how NIDS sensors should be positioned in a network, giving the typical sensor locations.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Sensors must be placed strategically so that the most valuable assets are defended. | "Place IDS sensors strategically to defend most valuable assets" | 062 - Intrusion Detection System, slide 7 | 062 - Intrusion Detection System::s07::1 | 0.88 | supported (ste gate) |
| 2 | Typical sensor locations include just inside the firewall, on the DMZ, on the server farm segment, and on segments connecting mainframe or midrange hosts. | "Just inside the firewall" | 062 - Intrusion Detection System, slide 7 | 062 - Intrusion Detection System::s07::1 | 0.20 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 062 - Intrusion Detection System, slide 7*

### A2b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Describe six preventive network security mechanisms that an organization can deploy to protect its network, explaining the role each mechanism plays.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A firewall controls incoming and outgoing network traffic according to predetermined security policies. | "Control incoming and outgoing traffic on network with predetermined security policies." | 061 - Network Security, slide 3 | 061 - Network Security::s03::1 | 0.80 | supported (ste gate) |
| 2 | A proxy server improves data security and network performance by acting as a firewall and web filter, sharing connections and caching data. | "Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests." | 061 - Network Security, slide 3 | 061 - Network Security::s03::1 | 0.79 | supported (ste gate) |
| 3 | Network segmentation | "Boundaries between network | 061 - Network | 061 - Network | 0.77 | supported (ste |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | creates boundaries between segments whose computing assets share a common function, risk or role. | segments where computing assets within the segment have a common function, risk or role within an organization." | Security, slide 3 | Security::s03::1 | | gate) |
| 4 | A remote access VPN gives individual hosts or clients secure access to the organization network from remote locations. | "Provides remote and secure access to an organization network to individual hosts or clients" | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.80 | supported (ste gate) |
| 5 | Zero Trust Network Access limits each user to only the access and permissions needed to fulfil their role. | "A user should only has access and permission that required to fulfill the role" | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.55 | supported (ste gate) |
| 6 | IDS/IPS mechanisms detect or prevent network attacks such as brute force, denial-of-service and exploitation of network vulnerabilities. | "To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities." | 061 - Network Security, slide 4 | 061 - Network Security::s04::1 | 0.79 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4*

## PART A - QUESTION 3

### A3a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State TWO (2) facts about the chain of trust in the Trusted Computing architecture, including how measurements are recorded and where the chain begins.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Each stage of the chain measures and validates the following stage. | "Each stage measures and validates the next one" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.60 | supported (ste gate) |
| 2 | The measurements produced during the chain are stored in Platform Configuration Registers on the TPM. | "Measurements go into Platform Configuration Registers (PCRs) on the TPM" | 073 - Trusted Computing, slide 8 | 073 - Trusted Computing::s08::1 | 0.56 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 073 - Trusted Computing, slide 8*

### A3b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain the roles of the two primary system components of the Next Generation Secure Computing Base (NGSCB), describing what each component is and how it supports trusted operation of the platform.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Nexus is described as a special kernel that forms the core of the trusted operating environment. | "Special kernel (core of the trusted operating)" | 073 - Trusted Computing, slide 13 | 073 - Trusted Computing::s13::1 | 0.62 | supported (ste gate) |
| 2 | Nexus acts as a security kernel that is authenticated on boot. | "Security kernel, authenticated on boot" | 073 - Trusted Computing, slide 14 | 073 - Trusted Computing::s14::1 | 0.67 | supported (ste gate) |
| 3 | Nexus authenticates trusted programs. | "Authenticates trusted programs" | 073 - Trusted Computing, | 073 - Trusted Computing::s14:: | 0.75 | supported (ste gate) |

| | | | | | | |
|---|---|---|---|---|---|---|
| | | | slide 14 | 1 | | |
| 4 | Nexus provides the application interface to the TPM. | "Application interface to TPM" | 073 - Trusted Computing, slide 14 | 073 - Trusted Computing::s14::1 | 0.60 | supported (ste gate) |
| 5 | Nexus does not trust the operating system. | "Does not trust OS" | 073 - Trusted Computing, slide 14 | 073 - Trusted Computing::s14::1 | 0.50 | supported (ste gate) |
| 6 | The Nexus Computing Agent is a trusted software component that runs in trusted mode and communicates with Nexus. | "Runs in trusted mode that communicates with Nexus" | 073 - Trusted Computing, slide 15 | 073 - Trusted Computing::s15::1 | 0.62 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15*

## PART A - QUESTION 4

### A4a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State TWO (2) differences between morals and laws as described in the lecture on ethics and computer security.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Morals are described as traditions of belief concerning right and wrong conduct within a society. | "Morals are traditions of belief about right and wrong conduct" | 071 - Ethics and Computer Security, slide 5 | 071 - Ethics and Computer Security::s05::1 | 0.67 | supported (ste gate) |
| 2 | Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens. | "Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens" | 071 - Ethics and Computer Security, slide 5 | 071 - Ethics and Computer Security::s05::1 | 1.00 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 071 - Ethics and Computer Security, slide 5*

### A4b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State SIX (6) professional conduct requirements that the ACM code expects a computing professional to follow when carrying out computing work.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The professional must aim for high quality in the processes and products of their professional work. | "Strive to achieve high quality in both the processes and products of professional work." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.75 | supported (ste gate) |
| 2 | The professional must keep up high standards of competence, conduct and ethical practice. | "Maintain high standards of professional competence, conduct, and ethical practice." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.78 | supported (ste gate) |
| 3 | The professional must be aware of and respect the existing rules that apply to professional work. | "Know and respect existing rules pertaining to professional work." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.62 | supported (ste gate) |
| 4 | The professional must give thorough | "Give comprehensive and thorough evaluations of computer | 071 - Ethics and Computer | 071 - Ethics and Computer | 0.80 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | evaluations of computer systems and their impacts, including possible risks. | systems and their impacts, including analysis of possible risks." | Security, slide 12 | Security::s12::1 | | |
| 5 | The professional must only perform work that falls within their areas of competence. | "Perform work only in areas of competence." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.56 | supported (ste gate) |
| 6 | The professional must design and implement systems that are secure in a robust and usable way. | "Design and implement systems that are robustly and usably secure." | 071 - Ethics and Computer Security, slide 12 | 071 - Ethics and Computer Security::s12::1 | 0.67 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 071 - Ethics and Computer Security, slide 12*

## PART A - QUESTION 5

### A5a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain two characteristics of Trojan horse malware that distinguish its behaviour on an infected host.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Trojans disguise themselves as legitimate or benign software so users install them willingly. | "They usually masquerade as helpful or harmless programs" | 051 - Software Security, slide 12 | 051 - Software Security::s12::1 | 0.00 LOW | supported |
| 2 | Once running, a trojan steals private data, deletes files, records keystrokes, or opens a backdoor for further malware. | "begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed" | 051 - Software Security, slide 12 | 051 - Software Security::s12::1 | 0.64 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 051 - Software Security, slide 12*

### A5b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Discuss six malware attack techniques and propagation methods, explaining how each technique operates and the impact it has on an infected system or its users.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Rootkits conceal malicious processes and software on the infected system so that the attacker retains privileged remote access. | "Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access." | 051 - Software Security, slide 13 | 051 - Software Security::s13::1 | 0.75 | supported (ste gate) |
| 2 | Rootkits are typically installed after a vulnerability has been discovered, allowing the infected machine to remain under the malware author's control. | "They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author." | 051 - Software Security, slide 13 | 051 - Software Security::s13::1 | 0.60 | supported (ste gate) |
| 3 | Spyware steals user credentials and records | "They steal user logins and passwords, document sites | 051 - Software Security, slide | 051 - Software Security::s13::1 | 0.29 LOW | partly supporte |

| | | | | | | |
|---|---|---|---|---|---|---|
| | activity such as visited sites and keystrokes, which can lead to identity theft and compromised bank details. | visited, log keystrokes and even redirect browsers to unwanted sites." | 13 | | | |
| 4 | A virus can be attached to an executable by appending the virus body to the host program. | "Append a virus body to a program" | 051 - Software Security, slide 10 | 051 - Software Security::s10::1 | 0.50 | supported (ste gate) |
| 5 | A virus can hijack execution by overwriting the program header so that the entry point switches to the virus code. | "Over write a program header to switch the entry point to a virus" | 051 - Software Security, slide 10 | 051 - Software Security::s10::1 | 0.55 | supported (ste gate) |
| 6 | The Morris worm propagated across the Arpanet by exploiting a debugging feature of sendmail that permitted remote execution. | "Used a debugging feature of sendmail (remote execution)" | 051 - Software Security, slide 7 | 051 - Software Security::s07::1 | 0.36 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7*

## PART A - QUESTION 6

### A6a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State the four goals of access control and identify the component that makes authorization decisions.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The goals of access control are granting access, limiting access, preventing access and revoking access. | "Goals of access control: Granting access Limiting access Preventing access Revoking access" | 023 - Access Control and Authorization, slide 4 | 023 - Access Control and Authorization::s04::1 | 1.00 | supported (ste gate) |
| 2 | Authorization decisions are made by the reference monitor. | "Reference monitor makes authorization decisions." | 023 - Access Control and Authorization, slide 4 | 023 - Access Control and Authorization::s04::1 | 0.80 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 023 - Access Control and Authorization, slide 4*

### A6b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Refer to your answer in (a). Explain six points about the formal security models used for access control, covering the Bell-La Padula model, the Biba model and the Chinese Wall model, including the security concern each addresses and the rules that govern access under the Chinese Wall model.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The Bell-La Padula model is a formal security model that deals with access control only. | "Bell-La Padula (BLP) model: access control only" | 024 - Formal Security Model, slide 5 | 024 - Formal Security Model::s05::1 | 0.67 | supported (ste gate) |
| 2 | The Biba model is a formal security model that adds integrity | "Biba model: additional integrity verification" | 024 - Formal Security Model, slide 5 | 024 - Formal Security Model::s05::1 | 0.57 | supported (ste gate) |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | verification. | | | | | |
| 3 | The Chinese Wall model is concerned with identifying conflicts of interest. | "Chinese Wall model: identification of conflicts of interest" | 024 - Formal Security Model, slide 5 | 024 - Formal Security Model::s05::1 | 0.83 | supported (ste gate) |
| 4 | The Chinese Wall simple security rule permits a subject to access an object only when that object lies within the subject's existing Wall (the same company datasets already accessed) or falls in a completely separate conflict of interest class. | "is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class." | 024 - Formal Security Model, slide 25 | 024 - Formal Security Model::s25::1 | 0.46 LOW | supported |
| 5 | Under the Chinese Wall *-property, a write is allowed only when the simple security rule permits it and the subject cannot read any unsanitized object belonging to a different company dataset from the one being written to. | "access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information." | 024 - Formal Security Model, slide 26 | 024 - Formal Security Model::s26::1 | 0.46 LOW | supported |
| 6 | In the Chinese Wall policy, permissions change dynamically because a subject's access rights depend on the history of past accesses. | "Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses" | 024 - Formal Security Model, slide 24 | 024 - Formal Security Model::s24::1 | 0.69 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 5*

## PART A - QUESTION 7

### A7a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*List TWO (2) key points about software insecurity and buffer overflows as presented in the Software Security lecture.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Software insecurity arises because an attacker can modify system resources that are critical for program execution, such as the instruction pointer or function call addresses. | "Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc." | 051 - Software Security, slide 30 | 051 - Software Security::s30::1 | 0.72 | supported (ste gate) |
| 2 | A major source of software insecurity is the failure to properly validate user input. | "One of the key sources for software insecurity is failed validation of user input." | 051 - Software Security, slide 30 | 051 - Software Security::s30::1 | 0.67 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 051 - Software Security, slide 30*

### A7b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Compare the security mechanisms found in Windows with those found in UNIX, focusing on the strengths and weaknesses of each. Provide six (6) distinct points covering user account and object management, access control, administration requirements, and missing features.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Windows provides complex built-in mechanisms for managing user accounts and objects as well as controlling access. | "Windows systems contain complex security mechanisms for user account and object management as well as access control." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.83 | supported (ste gate) |
| 2 | The very complexity of Windows security can backfire, since misconfiguration or implementation bugs can cause serious security incidents. | "The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.46 LOW | supported |
| 3 | UNIX offers a set of flexible security mechanisms, but their effectiveness depends on careful and knowledgeable administration. | "UNIX provides a set of flexible security mechanisms; however, their efficacy relies on careful and knowledgable administration." | 042 - Linux Security, slide 28 | 042 - Linux Security::s28::1 | 0.58 | supported (ste gate) |
| 4 | UNIX lacks several key features suggested by security models, such as ACLs or security levels. | "UNIX does not provide several key features suggested by security models, e.g. no ACLs or security levels." | 042 - Linux Security, slide 28 | 042 - Linux Security::s28::1 | 0.78 | supported (ste gate) |
| 5 | The main security strength of UNIX comes from its open source implementation, which allows flaws to be discovered and fixed early. | "The main security strength lies in its open source implementation; hence, security flaws are discovered and fixed early." | 042 - Linux Security, slide 28 | 042 - Linux Security::s28::1 | 0.58 | supported (ste gate) |
| 6 | Windows security mechanisms include discretionary access control (DACS) that enable fine-grained access control of heterogeneous entities in Windows itself as well as applications. | "DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications." | 041 - Windows Security, slide 21 | 041 - Windows Security::s21::1 | 0.69 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 041 - Windows Security, slide 21; 042 - Linux Security, slide 28*

## PART A - QUESTION 8

### A8a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*List two classes of threats and, for each, state which security objective (confidentiality, integrity or availability) is affected and which service counters it.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Disclosure is a threat class involving unauthorized access to information, and | "Disclosure - unauthorized access to information" | 011 - Introduction to Computer Security, slide 10 | 011 - Introduction to Computer Security::s10::1 | 0.40 LOW | partly supporte |

© Hak Cipta Universiti Teknologi MARA 

| | | | | | | |
|---|---|---|---|---|---|---|
| | confidentiality services counter it. | | | | | |
| 2 | Deception is a threat class involving acceptance of false data, and integrity services counter it. | "Deception - acceptance of false data" | 011 - Introduction to Computer Security, slide 10 | 011 - Introduction to Computer Security::s10::1 | 0.40 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 011 - Introduction to Computer Security, slide 10*

### A8b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*The Samy worm spread through MySpace by exploiting a cross-site scripting flaw. Explain six aspects of this incident, covering how the JavaScript was injected, how the worm propagated through user profiles and friend lists, and the scale of the resulting infection.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The worm injected JavaScript into a user profile by writing to document.body.innerHTML. | "Inject Javascript into a user profile using document.body.innerHTML" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.70 | supported (ste gate) |
| 2 | The worm obtained the list of a user's heroes by issuing a GET request on a user profile. | "Get the list of user's heros by using a GET on a user profile" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.38 LOW | supported |
| 3 | The worm added Samy as a friend by performing an XML-HTTP request on the addFriends page. | "Add Samy as a field by performing XML-HTTP on the addFriends page" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.70 | supported (ste gate) |
| 4 | Any visitor to an infected user's page had their own profile and friends list infected with the JavaScript and with Samy. | "Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy" | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.64 | supported (ste gate) |
| 5 | The infection ultimately reached approximately 1,000,000 MySpace profiles. | "Eventually about 1,000,000 MySpace profiles were infected." | 052 - Web Security, slide 15 | 052 - Web Security::s15::1 | 0.43 LOW | supported |
| 6 | The underlying flaw is that any web application returning user input without filtering is a potential XSS vulnerability, permitting arbitrary JavaScript to run in the victim's browser. | "Any web application that returns user input without filtering is a potential XSS vulnerability!" | 052 - Web Security, slide 13 | 052 - Web Security::s13::1 | 0.53 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15*

## PART A - QUESTION 9

### A9a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain the two stages of the biometric authentication process and state what happens during each stage.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The identification stage involves acquiring the biometric sample, creating the master characteristics, and storing those master characteristics. | "Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics" | 072 - Biometrics and Authentication, slide 5 | 072 - Biometrics and Authentication::s05::1 | 0.33 LOW | supported |
| 2 | The authentication stage involves further acquisition(s), comparison of the presented sample, and a decision. | "Authentication Stage Acquisition(s) Comparison Decision" | 072 - Biometrics and Authentication, slide 5 | 072 - Biometrics and Authentication::s05::1 | 0.62 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 072 - Biometrics and Authentication, slide 5*

## A9b - 6 marks - supported by lecture slides (not lecturer-marked)

### Question:

*A bank plans to deploy biometric authentication at its branch counters. Explain the biometric mechanisms and technologies involved, covering how biometrics are defined, the categories of biometric applications, and the characteristics and drawbacks of specific technologies.*

### Marking points:

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person from another and can theoretically be used for identification or verification of identity. | "A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity." | 072 - Biometrics and Authentication, slide 2 | 072 - Biometrics and Authentication::s02::1 | 0.92 | supported (ste gate) |
| 2 | Biometric applications are categorized into two sectors: physiological and behavioural. | "Biometric applications available today are categorized into 2 sectors" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.71 | supported (ste gate) |
| 3 | Physiological biometrics include iris, fingerprints, hand, retinal and face recognition. | "Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.67 | supported (ste gate) |
| 4 | Behavioural biometrics include voice, typing pattern and signature. | "Behavioural: Voice, Typing pattern, Signature" | 072 - Biometrics and Authentication, slide 4 | 072 - Biometrics and Authentication::s04::1 | 0.67 | supported (ste gate) |
| 5 | Iris scanning reads the unique pattern of the iris, requires no touch, and overcomes issues of retinal scanners. | "Scans unique pattern of iris" | 072 - Biometrics and Authentication, slide 10 | 072 - Biometrics and Authentication::s10::1 | 0.36 LOW | partly supporte |
| 6 | Fingerprint biometrics suffer disadvantages such as racial issues, dirt, grime and wounds, finger placement, large database processing, and spoofing so liveness is important. | "Can be spoofed - liveness important!" | 072 - Biometrics and Authentication, slide 7 | 072 - Biometrics and Authentication::s07::1 | 0.17 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7*

© Hak Cipta Universiti Teknologi MARA 

# PART A - QUESTION 10

## A10a - 2 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain two password security controls that a system administrator can apply to protect password files and accounts.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Access control should be applied to the password files themselves. | "Access control applied to password files" | 022 - Identification and Authentication, slide 12 | 022 - Identification and Authentication::s12::1 | 0.57 | supported (ste gate) |
| 2 | Accounts should be de-activated after multiple failed login attempts. | "De-activation of accounts after multiple failed logins" | 022 - Identification and Authentication, slide 12 | 022 - Identification and Authentication::s12::1 | 0.75 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 022 - Identification and Authentication, slide 12*

## A10b - 6 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Describe six aspects of single sign-on and Kerberos as authentication mechanisms in large distributed environments, covering the motivation for single sign-on, the solutions available, the design criteria of Kerberos, and how a user logs in to Kerberos.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Single sign-on reduces the need for users to memorize passwords. | "Reduce the need to memorize passwords" | 022 - Identification and Authentication, slide 16 | 022 - Identification and Authentication::s16::1 | 0.57 | supported (ste gate) |
| 2 | Single sign-on reduces the time users spend typing passwords. | "Reduce the time spent on typing passwords" | 022 - Identification and Authentication, slide 16 | 022 - Identification and Authentication::s16::1 | 0.43 LOW | supported |
| 3 | Single sign-on reduces the effort of password maintenance. | "Reducing password maintenance effort" | 022 - Identification and Authentication, slide 16 | 022 - Identification and Authentication::s16::1 | 0.67 | supported (ste gate) |
| 4 | Kerberos is designed to be secure against eavesdropping by never transmitting passwords in clear text. | "Security against eavesdropping: no password transmission in clear text." | 022 - Identification and Authentication, slide 18 | 022 - Identification and Authentication::s18::1 | 0.60 | supported (ste gate) |
| 5 | Kerberos is designed for transparency, so the user is unaware of any authentication beyond the initial login. | "Transparency: user is not aware of any authentication beyond an initial login." | 022 - Identification and Authentication, slide 18 | 022 - Identification and Authentication::s18::1 | 0.70 | supported (ste gate) |
| 6 | During Kerberos login, the user enters a user name and password at a client workstation, and the hash of the password becomes the client's secret key. | "The hash value of his password KU = h(P) becomes a secret key of the client/user." | 022 - Identification and Authentication, slide 19 | 022 - Identification and Authentication::s19::1 | 0.55 | supported (ste gate) |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 19*

© Hak Cipta Universiti Teknologi MARA

# PART B - QUESTION 1

## B1a - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*An organisation deploys an intrusion detection system to defend its network against malware and other attacks. Explain five aspects of how such detection and defence mechanisms work, covering what the IDS does, how misuse detection recognises attacks, and the limitations of these approaches.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The IDS detects malicious activity occurring in computer systems. | "Detects malicious activity in computer systems" | 062 - Intrusion Detection System, slide 2 | 062 - Intrusion Detection System::s02::1 | 0.71 | supported (ste gate) |
| 2 | The IDS can identify and stop attacks that are currently in progress. | "Identifies and stops attacks in progress" | 062 - Intrusion Detection System, slide 2 | 062 - Intrusion Detection System::s02::1 | 0.50 | supported (ste gate) |
| 3 | Misuse detection represents attacks as patterns or signatures so that even variations of the same attack can be detected. | "there are ways to represent attacks in the form of a pattern or a signature so that even variations of the same attack can be detected" | 062 - Intrusion Detection System, slide 17 | 062 - Intrusion Detection System::s17::1 | 0.90 | supported (ste gate) |
| 4 | Misuse detection is of little use against unknown attack methods, since it only recognises known bad behaviour. | "They can detect many or all known attack patterns, but they are of little use for unknown attack methods." | 062 - Intrusion Detection System, slide 17 | 062 - Intrusion Detection System::s17::1 | 0.46 LOW | supported |
| 5 | A passive detection system can only log and alert when an attack is identified, and cannot actively stop an attack in progress. | "Cannot take active actions to stop an attack in progress" | 062 - Intrusion Detection System, slide 29 | 062 - Intrusion Detection System::s29::1 | 0.39 LOW | supported |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 062 - Intrusion Detection System, slide 17; 062 - Intrusion Detection System, slide 2; 062 - Intrusion Detection System, slide 29*

## B1b - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*State five distinct threat classes or attack techniques that can compromise a computer system, and for each one identify a countermeasure or defence mechanism that addresses it.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Threats are potential violations of security, distinct from attacks which are actual violations. | "Threats: A threat is a "potential" violation of security" | 011 - Introduction to Computer Security, slide 9 | 011 - Introduction to Computer Security::s09::1 | 0.67 | supported (ste gate) |
| 2 | Forces of nature are dangerous threats that disrupt information storage, transmission and use, requiring controls and contingency plans. | "Forces of nature are among the most dangerous threats" | 011 - Introduction to Computer Security, slide 13 | 011 - Introduction to Computer Security::s13::1 | 0.33 LOW | partly supporte |
| 3 | Software threats include modification of program code and viruses/self-replicating code. | "Modification of program code" | 051 - Software Security, slide 2 | 051 - Software Security::s02::1 | 0.22 LOW | partly supporte |
| 4 | Code injection attacks | "Script injection (e.g. XSS)" | 051 - Software | 051 - Software | 0.18 LOW | partly supporte |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | such as XSS and SQL injection are software threats that must be defended against. | | Security, slide 2 | Security::s02::1 | | |
| 5 | Input cleansing and validation is a defence mechanism that models expected input and discards what does not fit. | "Input cleansing and validation (Input Validation/Sinatization)" | 051 - Software Security, slide 29 | 051 - Software Security::s29::1 | 0.27 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 011 - Introduction to Computer Security, slide 13; 011 - Introduction to Computer Security, slide 9; 051 - Software Security, slide 2; 051 - Software Security, slide 29*

## PART B - QUESTION 2

### B2a - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Explain five ethical obligations that the ACM code expects a computing professional to uphold when developing and deploying technology, and explain why such a professional code may not always be enforceable.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | The professional should work for the benefit of society and human welfare, recognising that everyone affected counts as a stakeholder. | "Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.25 LOW | supported |
| 2 | The professional should refrain from causing harm through computing work. | "Avoid harm." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.12 LOW | supported |
| 3 | The professional should act truthfully and in a manner that earns trust. | "Be honest and trustworthy." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.00 LOW | supported |
| 4 | The professional should safeguard personal data and the private information of others. | "Respect privacy." | 071 - Ethics and Computer Security, slide 11 | 071 - Ethics and Computer Security::s11::1 | 0.00 LOW | supported |
| 5 | The code may fail to be enforceable because it functions as a conduct code rather than a legal instrument. | "It's a code of conduct, not a legal document." | 071 - Ethics and Computer Security, slide 9 | 071 - Ethics and Computer Security::s09::1 | 0.27 LOW | supported |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 9*

### B2b - 5 marks - supported by lecture slides (not lecturer-marked)

**Question:**

*Discuss the ethical concerns raised by the staff member's action and the company's responsibility, referring to privacy, the ACM code of ethics, and the nature of professional ethical codes.*

**Marking points:**

| No. | Point (1 mark) | Evidence quote | Source | Chunk | Stem overlap | Entailment |
|---|---|---|---|---|---|---|
| 1 | Explain that privacy concerns protecting an | "Protecting one's personal information" | 071 - Ethics and Computer Security, slide | 071 - Ethics and Computer Security::s13::1 | 0.33 LOW | partly supporte |

© Hak Cipta Universiti Teknologi MARA

| | | | | | | |
|---|---|---|---|---|---|---|
| | individual's personal information, which the staff member failed to do. | | 13 | | | |
| 2 | Explain that information accessibility concerns what information a person has the right to obtain about others and how it can be used, which the staff member violated. | "Deals with what information a person has the right to obtain about others and how the information can be used" | 071 - Ethics and Computer Security, slide 13 | 071 - Ethics and Computer Security::s13::1 | 0.61 | supported (ste gate) |
| 3 | State that the ACM has a code of ethics and professional conduct that the staff member should have followed. | "Association of Computing Machinery ACM (founded 1947) has a code of ethics and professional conduct." | 071 - Ethics and Computer Security, slide 7 | 071 - Ethics and Computer Security::s07::1 | 0.55 | supported (ste gate) |
| 4 | Describe ethics as a documented set of acceptable behaviors for professional groups that identifies specific actions as appropriate or inappropriate. | "Documented set of acceptable behaviors for professional or social groups." | 071 - Ethics and Computer Security, slide 6 | 071 - Ethics and Computer Security::s06::1 | 0.60 | supported (ste gate) |
| 5 | Explain that because ethics are defined by the group, the company must enforce its own acceptable behavior standards rather than relying on external law. | "Defined by the group." | 071 - Ethics and Computer Security, slide 6 | 071 - Ethics and Computer Security::s06::1 | 0.12 LOW | partly supporte |

*Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.*
*Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).*
*Citations: 071 - Ethics and Computer Security, slide 13; 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 7*

*End of marking scheme.*

© Hak Cipta Universiti Teknologi MARA